Processo de Gestão de Identidades

Documento de Especificação (Procedimento)

Ref. COBIT® – DS5.3

Índice

1. OBJETIVO 3
2. ESCOPO DO PROCESSO 3
3. OBJETIVOS DE CONTROLE COBIT 4.1 3
4. CONCEITOS 4
5. DIRETRIZES E DEFINIÇÕES DO PROCESSO 4
6. INTERFACE COM OUTROS PROCESSOS 6
7. FLUXOGRAMAS 7
8. DESCRIÇÃO DAS ATIVIDADES DO FLUXOGRAMA 9
9. MATRIZ RACI 11
10. PAPÉIS E RESPONSABILIDADES 12
11. INDICADORES 13
12. DOCUMENTOS RELACIONADOS 13
13. CONTROLE DE VERSÃO 13

1. Objetivo

Estabelecer procedimentos padronizados que permitam gestão efetiva de todas as identidades de usuários (internos, externos e temporários) e seus respectivos direitos/privilégios de acesso a Serviços e Sistemas de TI. Tais procedimentos abordam as atividades de concessão, alteração, revogação e revisão de acessos, considerando etapas de aprovação, análise de segregação de funções sobre perfis, entre outras.

2. Escopo do Processo

O escopo do processo de Gestão de Acessos e Identidades envolve os procedimentos de concessão, revogação, alteração e revisão de acessos aos Serviços e Sistemas sob responsabilidade da Área de TI da Smiles em ambiente de Produção.

Em relação aos sistemas, este processo cobre a seguinte lista específica: Siebel, Smiles Contábil, RH Smiles, Oracle EBS, AD (Active Directory), B2E Faturamento.

3. Objetivos de Controle COBIT 4.1

Processo / Objetivos de Controle	Situação	Análise sobre o processo atual
DS5 – Garantir a Segurança dos Sistemas		
DS5.3 Gestão de Identidades Todos os usuários (internos, externos e temporários) e suas atividades nos sistemas de TI (aplicação de negócio, desenvolvimento, operação e manutenção de sistemas) devem ser identificáveis de modo exclusivo. Os direitos de acesso dos usuários aos sistemas e dados devem estar em conformidade com as necessidades dos negócios e com os requisitos da função definidos e documentados. Os direitos de acesso devem ser solicitados pela gestão de usuários, aprovados pelo proprietário do sistema e implementados pelo responsável pela segurança. As identidades e os direitos de acesso dos usuários devem ser mantidos em um repositório central. É necessário implementar e manter atualizadas medidas técnicas e de procedimentos com boa relação custo-benefício para determinar a identificação dos usuários, implementar a devida autenticação e impor direitos de acesso.	**Contemplado**	Processo atual cobre procedimentos que abordam as atividades de concessão, alteração, revogação e revisão de acessos, considerando etapas de aprovação, análise de segregação de funções sobre perfis, entre outras.

4. Conceitos

Os principais conceitos referentes ao processo de Gestão de Acessos e Identidades são:

- **Acesso:** refere-se ao nível e extensão de uma funcionalidade ou dados de um Sistema de Informação que um usuário tem o direito de usar.
- **Identidade:** podemos considerar um conjunto de informações sobre um usuário que o distingue como único e que verifica seu status dentro da organização. Por definição, a Identidade do usuário deve ser exclusiva e intransferível.
- **Controle de Acesso:** o controle que deve, prioritariamente, garantir o registro e manter o histórico de todos os acessos concedidos, alterados ou removidos para usuários, de maneira a prover informações para atividades de auditoria e de investigação de eventuais violações de segurança.
- **Conta Administrativa:** conta de usuário com privilégios de administração sobre as funcionalidades de um determinado sistema, bem como privilégios de administração das contas de usuários e contas de serviço do referido sistema. Também é conhecido como “super-usuário”.
- **Conta de Usuário:** contas utilizadas por usuários para prover sua autenticação em Serviços ou Sistemas de TI.
- **Conta de Serviço:** contas utilizadas para prover autenticação entre sistemas de informação.
- **Colaborador:** funcionário contratado pela Smiles S.A. em regime CLT.
- **Direitos ou Privilégios:** refere-se a concessão de acessos ou de permissões para um usuário, pessoa ou papel.
- **Prestador de Serviços (terceiro):** recurso que presta serviços através de contrato celebrado entre a Smiles S.A. e a respectiva empresa pelo qual é efetivamente contratado, sem possuir vínculo empregatício com a Smiles.
- **Usuário:** colaborador ou prestador de serviços (terceiro) que utiliza Serviços ou Sistemas de TI para desempenhar suas tarefas e rotina de trabalho.

5. Diretrizes e Definições do Processo

O processo de Gestão de Acessos e Identidades possui as seguintes diretrizes e definições:

- **Definição única de Processo:** haverá apenas um único processo de Gestão de Acessos e Identidades para a SMILES.

- **Canal para Solicitações de Acesso:** toda concessão, revogação e/ou alteração de acesso deve ser solicitada através da abertura de uma requisição (chamado) na ferramenta da Central de Serviços de TI (JIRA Service Desk).

- **Transferência de área ou função:** o gestor que estiver cedendo um colaborador para outra área ou função deve providenciar a revogação dos acessos que não serão mais utilizados pelo mesmo. O gestor que estiver recebendo o colaborador transferido de área ou de função, deve orientar o colaborador a solicitar a concessão dos acessos necessários para sua nova atividade.

    - Esta ação também se aplica aos prestadores de serviços (terceiros), quando eventualmente ocorrer mudança de suas funções dentro da Smiles.

- **Periodicidade da Revisão de Acessos:** Os acessos aos sistemas que fazem parte do escopo deste processo devem ser revisados com frequência mínima anual. A revisão deve ser focada na revogação de acessos indevidos, tendo como referência a Política de Segregação de Funções de TI estabelecida.

- **Aprovações Mínimas Necessárias:** a concessão, alteração ou revogação de acessos só poderá ser realizada com autorizações/aprovações mínimas da área de Segurança da Informação e do Gestor Imediato do Solicitante.

- **Contratação ou Desligamento de Usuários:** a concessão de acessos baseada em contratação de colaborador e/ou a revogação de acessos baseada em desligamento de um colaborador deve ser notificada e solicitada pela área de Recursos Humanos da Smiles.

    - No caso de prestador de serviços (terceiro), a notificação e solicitação deve ser realizada pelo Gestor Responsável pelo Contrato.

- **Revogação Emergencial de Acessos:** em casos excepcionais, pode ser necessário efetuar a revogação imediata dos acessos de um colaborador ou prestador de serviços (terceiros), antes mesmo da abertura de requisição na ferramenta da Central de Serviços de TI.

    - Nestas situações, a área de Segurança da Informação deverá ser informada por e-mail, telefone ou outro canal de comunicação rápida tomando ciência da situação e providenciando a revogação imediata dos acessos.

    - Após a efetivação da revogação é mandatória a abertura de uma requisição de revogação na ferramenta da Central de Serviços de TI, para fins de histórico e rastreabilidade.

- **Aprovações Adicionais para Contas Administrativas e Contas de Serviço:** a concessão, alteração ou revogação de acessos em contas administrativas e/ou contas de serviço só poderá ser realizada considerando, além das aprovações mínimas necessárias, a aprovação adicional da área de Operações de TI e Arquitetura de TI.

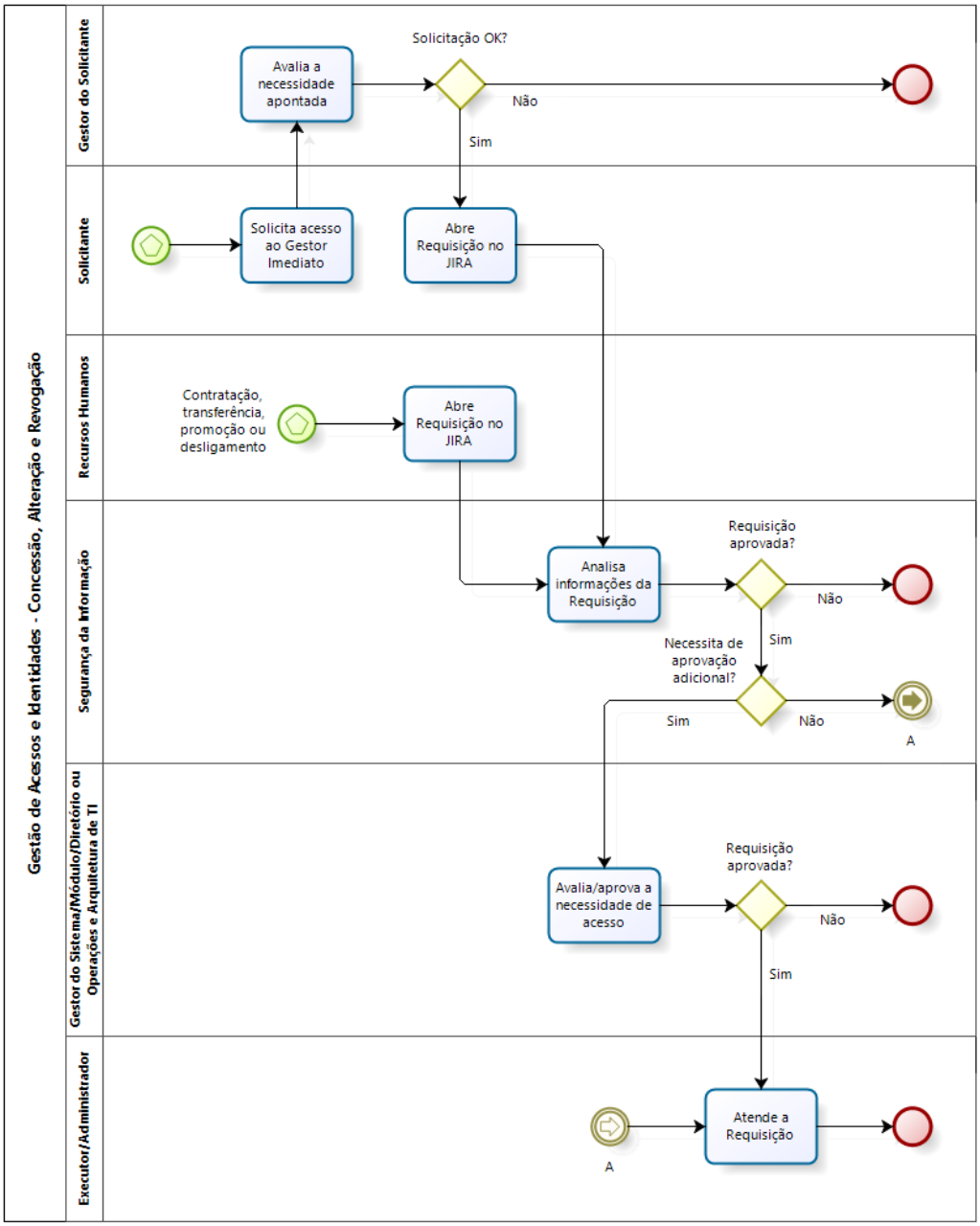
- **Bloqueio ou Revogação por Inatividade:** é altamente recomendável que os acessos sejam bloqueados ou revogados em caso de inatividade maior ou igual a 90 dias, considerando medidas técnicas automatizadas para realização desta ação.

6. Interface com outros processos

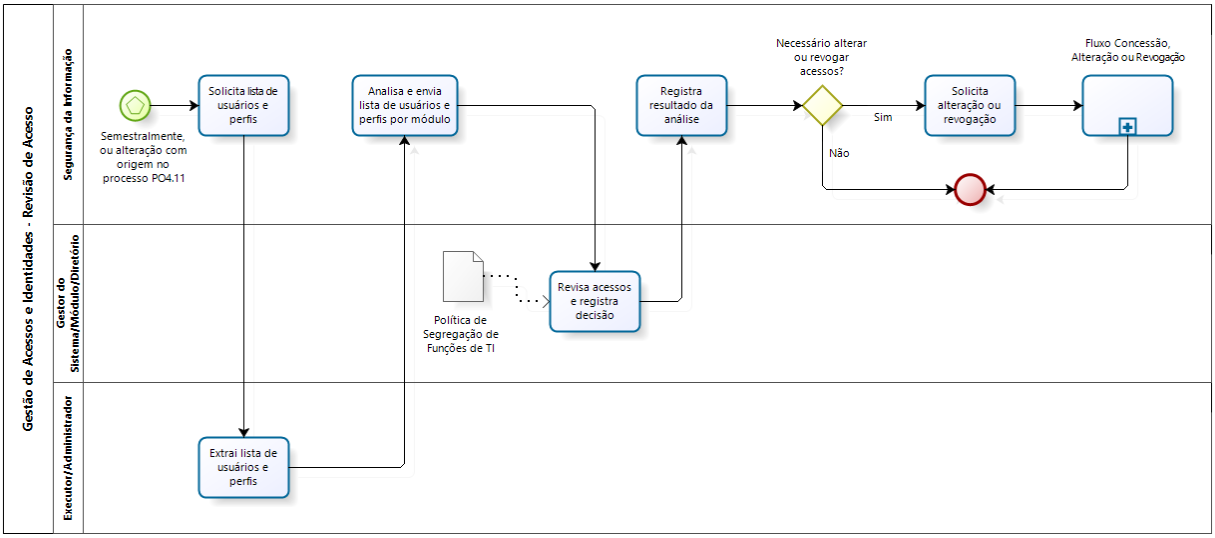
- **Gestão de Segregação de Funções de TI**
  - O processo de Gestão de Segregação de Funções em TI e sua respectiva Política de Segregação de Funções de TI devem ser considerados durante a revisão de acessos aos sistemas que fazem parte do escopo deste processo.
- **Gerenciamento de Incidentes de Segurança da Informação**
  - Acessos indevidos ou privilégios de acesso incorretos poderão ocasionar a abertura de um Incidente de Segurança da Informação.
- **Gerenciamento de Mudanças**
  - Uma vez que a função de Analista de Segurança da Informação é membro do CAB no processo de Gestão de Mudanças, convém que o mesmo realize questionamentos relacionados à Gestão de Acessos e Identidades quando ocorrer implantação de novos sistemas ou alteração significantes em sistemas já implantados, de forma a resguardar os requerimentos de Gestão de Acessos, tais como criação/alteração de acessos e perfis.

7. Fluxogramas

7.1 Fluxo de Gestão de Acessos e Identidades – Concessão, Alteração e Remoção



7.2 Fluxo de Gestão de Acessos e Identidades – Revisão de Acesso



8. Descrição das Atividades do Fluxograma

8.1 – Atividades de Gestão de Acessos e Identidades – Concessão, Alteração e Remoção

Passo	Atividade	Executor	Descrição	Passo Seguinte
01	Solicita acesso ao Gestor Imediato	Solicitante	Nesta atividade, o Solicitante envia pedido de acesso ao seu Gestor Imediato. Sob demanda de necessidade de acesso, o Solicitante solicita acesso necessário ao Gestor Imediato por e-mail.	02
02	Avalia a necessidade apontada	Gestor do Solicitante	Nesta atividade, o Gestor do Solicitante avalia a necessidade de acesso solicitada. Ao receber o e-mail do Solicitante com a solicitação de acesso, o Gestor do Solicitante avalia a necessidade de acesso e responde o e-mail com aprovação ou reprovação do acesso permitindo a formalização da requisição pela ferramenta JIRA. Caso o Gestor Imediato Aprove a solicitação de acesso, o Solicitante registra uma requisição no JIRA. (Segue para o passo 04) Caso o Gestor Imediato Reprove a solicitação de acesso, o Solicitante não dará continuidade a solicitação. (Fim)	03 ou Fim
03	Abre Requisição no JIRA	Solicitante	Nesta atividade, o Solicitante abre uma Requisição no JIRA. Após receber o e-mail de aprovação do seu Gestor Imediato, o Solicitante registra uma solicitação na ferramenta JIRA.	05
04	Abre Requisição no JIRA	Recursos Humanos	Nesta atividade, o Solicitante abre uma Requisição no JIRA. Sob demanda de Novo Acesso, Revogação de Acesso ou Alteração de acesso por Transferência ou Promoção, Recursos Humanos registra requisição de acesso no JIRA.	05
05	Analisa informações da Requisição	Segurança da Informação	Nesta atividade, a equipe de Segurança da Informação analisa as informações da Requisição. Após requisição aberta pelo Solicitante com aprovação do Gestor Imediato ou requisição aberta RH para concessão, alteração ou revogação de acesso, a equipe de Segurança da Informação analisa as informações da requisição e aprova ou reprova o acesso. Adicionalmente, de acordo com o tipo de solicitação, pode ser necessária uma aprovação adicional do Gestor do Sistema/Módulo/Diretório ou de Operações e Arquitetura de TI. Caso Segurança da Informação aprove a requisição de acesso e identifique necessidade de aprovação adicional de acesso, segue para o Gestor do Sistema/Módulo/Diretório ou Operações e Arquitetura de TI aprovarem ou reprovarem a requisição (Segue para passo 06) Caso Segurança da Informação aprove a requisição de acesso e identifique que não há necessidade de aprovação adicional, segue para o executor atender a requisição. (Segue para o passo 07) Caso Segurança da Informação reprove a requisição de acessos, a mesma é encerrada com a justificativa de recusa. (Fim)	06, 07 ou Fim
06	Avalia/aprova a necessidade de acesso	Gestor do Sistema/Módulo/ Diretório ou Operações e Arquitetura de TI	Nesta atividade, o Gestor do Sistema/Módulo/Diretório ou Operações e Arquitetura de TI avalia/aprova a necessidade de acesso. Após identificado necessidade de aprovação complementar pela equipe de Segurança da Informação, o Gestor do Sistema/Módulo/Diretório ou Operações e Arquitetura de TI avalia a Requisição de acesso aprovando ou reprovando a necessidade de acesso. Caso a requisição seja aprovada, segue para o Executor/Administrador atender a requisição. (Segue para passo 07)	07 ou Fim

Passo	Atividade	Executor	Descrição	Passo Seguinte
			Caso a requisição seja reprovada, o registro é encerrado com a justificativa da recusa do acesso. (Fim)	
07	Atende a Requisição	Executor / Administrador	Nesta atividade, o Executor/Administrador atende a Requisição. Após receber todas as aprovações de acesso necessárias para concessão ou alteração de acesso, o Executor/Administrador atende a Requisição, concede, altera ou revoga o acesso, conforme registro na ferramenta JIRA.	Fim

8.2 Atividades de Gestão de Acessos e Identidades – Revisão de Acesso

Passo	Atividade	Executor	Descrição	Passo Seguinte
01	Solicita lista de usuários e perfis	Segurança da Informação	Nesta atividade, a equipe de Segurança da Informação solicita a lista de usuários e perfis. Semestralmente ou mediante entrada/solicitação originada no processo PO4.11 (Gestão de Segregação de Funções de TI), a equipe de Segurança da Informação solicita lista de usuários e perfis para o Executor/Administrador do sistema que será revisado.	02
02	Extrai lista de usuários e perfis	Executor / Administrador	Nesta atividade, o Executor/Administrador extrai a lista de usuários e perfis. Após receber solicitação de lista de usuários e perfis pela equipe de Segurança da Informação, o Executor/Administrador da ferramenta de acessos extrai lista de usuários e perfis para análise e revisão de acessos do sistema que será revisado.	03
03	Analisa e envia lista de usuários e perfis por módulo	Segurança da Informação	Nesta atividade, a equipe de Segurança da Informação analisa a lista de usuários e perfis por módulo. Após levantamento de acessos pelo Executor/Administrador da ferramenta de acessos, a equipe de Segurança da Informação Analisa e envia lista de usuários e perfis por módulo para revisão do Gestor do Sistema / Módulo / Diretório.	04
04	Revisa acessos e registra decisão	Gestor do Sistema / Módulo / Diretório	Nesta atividade, o Gestor do Sistema/Módulo/Diretório revisa os acessos da lista e registra sua decisão. Após análise e envio da lista pela equipe de Segurança da Informação, o Gestor do Sistema / Módulo / Diretório revisa os acessos e registra a decisão sobre a necessidade de revogações ou alterações de acessos. Nesta atividade, o Gestor do Sistema/Módulo/Diretório deve considerar os princípios de segregação de funções e nas matrizes de conflitos oriundas do Processo de Segregação de Funções de TI e na Política de Segregação de Funções de TI.	05
05	Registra resultado da análise	Segurança da Informação	Nesta atividade, a equipe de Segurança da Informação registra o resultado da análise. Após revisão do Gestor do Sistema/Módulo/Diretório, a equipe de Segurança da Informação registra no repositório oficial de documentação da SMILES as decisões de revogações ou alterações de acessos determinadas pelo Gestor do Sistema / Módulo / Diretório. Caso haja acessos para alterar ou revogar, deve ser aberta requisição para execução desta atividade conforme previsto no Fluxo de Concessão, Alteração e Revogação (Segue para passo 06). Caso não seja necessário alterar ou revogar acessos, aguarda novo ciclo de revisão. (Fim)	06 ou Fim

Passo	Atividade	Executor	Descrição	Passo Seguinte
06	Solicita alteração ou revogação	Segurança da Informação	Nesta atividade, a equipe de Segurança da Informação solicita alteração ou revogação de acessos para regularização. Após registro dos resultados no repositório oficial de documentação da SMILES, a equipe de Segurança da Informação solicita através de registro no JIRA a necessidade de alterações e/ou revogações de acesso. (Fluxo de Concessão, Alteração e Revogação).	Fim

9. Matriz RACI

Matriz RACI — **Gestão de Acessos e Identidades**
Concessão, Alteração ou Remoção de Acesso
R = Responsible | A = Accountable | C = Consulted | I = Informed
Executor | Principal Responsável | Consultado | Informado

Atividade	Atividades	CIO / Diretor de TI	Solicitante	Gestor do Solicitante	Recursos Humanos	Segurança da Informação	Gestor do Sistema / Módulo / Diretório ou Operações e Arquitetura de TI	Executor / Administrador
	Responsável pelo sucesso do processo	A						
01	Solicita acesso ao Gestor Imediato		R	I				
02	Avalia a necessidade apontada			R				
03	Abre Requisição no JIRA		R					
04	Abre Requisição no JIRA				R			
05	Analisa informações da Requisição		C		C	R		
06	Avalia/aprova a necessidade de acesso		C		C	C	R	
07	Atende a Requisição		I		I	I		R

Matriz RACI — **Gestão de Acessos e Identidades**
Revisão de Acesso
R = Responsible | A = Accountable | C = Consulted | I = Informed
Executor | Principal Responsável | Consultado | Informado

Atividade	Atividades	CIO / Diretor de TI	Segurança da Informação	Gestor do Sistema / Módulo / Diretório ou Operações e Arquitetura de TI	Executor / Administrador
	Responsável pelo sucesso do processo	A			
01	Solicita lista de usuários e perfis		R		I
02	Extrai lista de usuários e perfis		I		R
03	Analisa e envia lista de usuários e perfis por módulo		R	I	
04	Revisa acessos e registra decisão		I	R	
05	Registra resultado da análise		R		
06	Solicita alteração ou revogação		R		

10. Papéis e Responsabilidades

- **Segurança da Informação**
  - Área responsável pela revisão e publicação das Políticas de Segurança da Informação e Segregação de Funções de TI.
  - Responsável por analisar e dar parecer, através de aprovação formal, sobre demandas de acessos em sistemas, módulos ou diretórios que estejam sob sua gestão. Essas demandas podem variar entre concessão de acesso, alteração de privilégios ou revogação de acessos.
- **Gestor do Solicitante**
  - Gestor Imediato responsável por analisar a solicitação de acesso mediante atividades a serem executadas pelo Solicitante.
- **Gestor do Sistema/Módulo/Diretório**
  - Responsáveis por analisar e dar parecer, através de aprovação formal, sobre demandas de acessos em sistemas, módulos ou diretórios que estejam sob sua gestão. Essas demandas podem variar entre concessão de acesso, alteração de privilégios ou revogação de acessos.
  - Responsável por realizar a Revisão de Acessos do Sistema/Módulo/Diretório e interagir com áreas envolvidas para ajustar acessos e privilégios concedidos, conforme recomendações da Política de Segregação de Funções de TI.
- **Operações e Arquitetura de TI**
  - Área responsável por analisar e dar parecer, através de aprovação formal, sobre demandas de acessos associadas a Contas de Serviços ou Contas Administrativas.
- **Recursos Humanos**
  - Responsável por notificar e solicitar ajustes via requisição (chamado) para a TI em caso de contratação, transferência e promoção que alterem o cargo e/ou função executada e desligamento de colaboradores Smiles.
- **Executor/Administrador**
  - Responsável por atender as Requisições demandadas para concessão, alteração ou revogação de acessos, de acordo com instruções e aprovações/considerações contidas em cada chamado;
  - Devido privilégios de Administrador de Sistema/Módulo/Diretório, também deve atender as solicitações da equipe de Segurança da Informação para extração de listas contendo informações de usuários e perfis para ações posteriores relacionadas a este processo.

11. Indicadores

O processo possui a definição de alguns Indicadores de Desempenho para acompanhamento de sua evolução, conforme demonstrado abaixo:

- Mensalmente:
    - Quantidade de revogações realizadas por mês
    - Quantidade de contas administrativas (superusuários) criados ou alterados por mês
- Trimestralmente:
    - Percentual e Quantidade revisões de acesso realizadas nos sistemas do escopo do processo / quantidade de sistemas do escopo do processo

12. Documentos Relacionados

- Política de Segurança da Informação
- Política de Segregação de Funções de TI
- Processo de Gestão de Segregação de Funções de TI

13. Controle de Versão

Versão	Data	Responsável	Principais Alterações
1.0	27/04/2017	CHACON Consultoria	Primeira versão do documento.